

Conventional Vulnerability Scanners (e.g., MobSF, Androguard)

1. Input: Unprocessed Client APK Only
No statutory grounding or legal models



2. Analysis: Generic CWE Pattern Matching
Treats client APK as entire system



3. Epistemic Flaw: Unbounded Extrapolation
Hallucinates compliance on unobservables
(e.g., backend encryption, policies, training)



4. Output: Fictitious Scalar Percentage
'70% Compliant (Grade B)'
[Legally Invalid & Scientifically Unsound]

VS

The Reg2App Verification Framework (Epistemic & Evidence-Based)

1. Input: Decompiled APK + Legal Corpus
Formally encoded YAML regulation knowledge base



2. Formal Mapping & Observability
7-tuple model & 2D operator $\Omega(R)$
Partitions client-side vs. backend obligations



3. Provenance Graph DAG $G = (V, E)$
Rigorous chain linking legal clauses to
verifiable Dalvik & manifest bytecode witnesses



4. Output: 5-State Epistemic Space
State space $\{S, P, I, O, A\}$ & Coverage EC/ESC
+ Actionable Bilingual Reports (EN/Bengali)